SAMI ALI

Alexandria, VA | U.S. Citizen | (571) 290-8908 | samiali38183@gmail.com
linkedin.com/in/sami-ali-1a4b89345 | github.com/samiali38183 | samiali38183.github.io

EDUCATION

George Mason University Expected May 2028
B.S. Information Technology, Cybersecurity Minor

Northern Virginia Community College May 2026
A.S. Information Technology | GPA 3.7

EXPERIENCE

U.S. Department of Homeland Security (CBP), HS-POWER Program May 2026 – Aug 2026
Vulnerability Assessment Team Analyst Intern | Ashburn, VA

- Matched Nessus/Tenable scan results against the CISA Known Exploited Vulnerabilities (KEV) catalog to identify high-risk systems and aged findings.
- Designed a risk-based prioritization method weighing KEV status, asset criticality, exposure, EPSS and CVSS, and benchmarked remediation against CISA BOD 26-04 timelines.
- Built a multi-page Power BI dashboard and an executive briefing on actively exploited vulnerabilities and mitigations for technical and leadership audiences.
- Wrote compliance reports and remediation recommendations aligned with the NIST Cybersecurity Framework and FedRAMP.

PROJECTS

tripline – ATT&CK emulation and detection-gap measurement (Python) github.com/samiali38183/tripline | v0.2.1

- Runs Atomic Red Team emulations on Linux and Windows CI runners and replays Stratus Red Team and flaws.cloud AWS logs across 14 ATT&CK techniques, including setuid privilege escalation (T1548.001), LSASS credential dumping (T1003.001), cron persistence (T1053.003) and ingress tool transfer (T1105).
- Measured what defenders miss: the stock SigmaHQ setuid/setgid rule matched 0 of 36 events from the T1548.001 tests (it keys on a literal 'chmod u+s', so octal modes like 4755 also slip past); a custom rule closes it. 10 scenarios pass on recorded telemetry, 4 pending; 186 tests.

sinkline – Finds exploitable injection flows in Python web apps github.com/samiali38183/sinkline | v0.4.1

- Static analyzer that traces attacker-controlled request data to sinks across files and flags the classes pentesters exploit: SQL injection, OS command injection, SSRF, insecure deserialization, XSS and open redirect. Each finding carries the source-to-sink path; 42 rules mapped to OWASP Top 10 and CWE.
- Reports findings in public vulnerable apps (vulpy, dvpwa, Vulnerable-Flask-App); precision 1.000 and recall 0.984 on its own self-labeled 109-line benchmark. Found and fixed a shell-injection flaw (CWE-78) in its own GitHub Action (0.4.1).

kevgate – Hardened API with attack-surface tests in CI github.com/samiali38183/kevgate | v0.1.0

- FastAPI vulnerability-intake service with hashed scoped API keys, rate limiting and a STRIDE threat model, ranking findings by CISA KEV, EPSS, CVSS and asset criticality. Ships a hardened container and a Helm chart (restricted pod security, NetworkPolicy).
- Attack-surface tests run in CI: ZAP baseline scan (67 rules pass, 0 failures) and kind-cluster tests confirming an unlabeled pod is blocked, pod egress to the internet is denied and a privileged pod is rejected. Release image signed with cosign (keyless) with SBOM and provenance.

TECHNICAL SKILLS

Languages: Python
Offensive and Security: MITRE ATT&CK, Atomic Red Team, Stratus Red Team (replayed logs), taint analysis / SAST, OWASP Top 10, OWASP ZAP (CI baseline), Sigma, vulnerability management (Nessus/Tenable), CISA KEV / EPSS / CVSS
Cloud and DevOps: AWS fundamentals, Docker, Kubernetes / Helm (kind in CI), Terraform (validated, LocalStack), GitHub Actions
Tools: Git, pytest, Wireshark, Linux, Power BI

CERTIFICATIONS

Certifications: CompTIA Security+ | AWS Certified Cloud Practitioner
In progress: OSCP | AWS Certified Security – Specialty